1. Matriz de análisis

| Situación encontrada | Riesgo e impacto | C / I / D | Control puesto | Fundamento tecnico | Como verificaria el control |
|---|---|---|---|---|---|
| La cuenta soporte puede realizar prácticamente cualquier acción administrativa. | Un usuario de soporte podría modificar el sistema, acceder a información restringida o interrumpir ControlNet. | C, I, D | Revisar y limitar privilegios de sudo; permitir únicamente comandos administrativos necesarios para sus funciones. | El mínimo privilegio exige autorizar únicamente los accesos necesarios para las tareas asignadas y revisar los privilegios periódicamente (Ross & Pillitteri, 2024, control 03.01.05). NIST SP 800-171 Rev. 3. | Revisar sudo -l -U soporte y los archivos de configuración de sudo; comprobar que las tareas autorizadas funcionen y que las acciones administrativas ajenas al rol sean rechazadas. |
| La cuenta proveedor continúa activa después de finalizar el trabajo externo y no tiene vencimiento. | Una credencial conservada o comprometida podría permitir acceso posterior no autorizado. | C, I, D | Deshabilitar la cuenta cuando termine el servicio, establecer fechas de expiración y revisar sus llaves SSH y sesiones activas. | NIST contempla la gestión de cuentas, la separación de responsabilidades y el mínimo privilegio (Ross & Pillitteri, 2024, controles 03.01.01, 03.01.04 y 03.01.05). | Revisar chage -l proveedor, el estado de la cuenta, authorized_keys y las sesiones activas. Intentar iniciar una sesión de prueba después de deshabilitar la cuenta. |
| SSH permite contraseñas y varios técnicos conocen credenciales administrativas compartidas. | Se dificulta atribuir acciones a una persona y aumenta el riesgo de acceso no autorizado mediante credenciales filtradas. | C, I, D | Utilizar cuentas individuales, autenticación mediante llaves públicas cuando corresponda, restringir quién puede acceder por SSH y eliminar credenciales compartidas. | OpenSSH admite varios mecanismos de autenticación y permite administrar su comportamiento mediante sshd_config y archivos complementarios (Canonical, s. f.-a). | Examinar la configuración efectiva con sshd -T, revisar las llaves autorizadas y probar desde un cliente que un usuario individual válido pueda entrar y una contraseña no permitida sea rechazada. |
| Las llaves SSH para respaldos carecen de inventario y control | Una llave privada copiada podría permitir accesos automatizados | C, I, D | Inventariar las llaves, identificar propietarios y destinos, restringir | El principio de mínimo privilegio se aplica también a cuentas de proceso, accesos y | Inventariar las llaves y sus usos; revisar authorized_keys, permisos de archivos y registros |

| | | | | | |
|---|---|---|---|---|---|
| documentado. | o la extracción, alteración o eliminación de respaldos. | | permisos y limitar las operaciones que cada llave puede ejecutar. | funciones de seguridad (Ross & Pillitteri, 2024, control 03.01.05). | de autenticación. Probar que una llave de respaldo solo pueda realizar las operaciones asignadas. |
| El firewall carece de política documentada y existen servicios de utilidad desconocida. | Un servicio innecesario o expuesto a equipos que no lo requieren podría servir como punto de entrada o facilitar movimientos laterales. | C, I, D | Identificar servicios, puertos, protocolos, orígenes y dependencias; deshabilitar servicios innecesarios y aplicar reglas de mínimo acceso con UFW o Netfilter. | Netfilter permite filtrar tráfico y UFW facilita la creación de reglas de firewall de host, incluidas restricciones por origen y puerto (Canonical, s. f.-b). | Revisar ss -lntup, sudo ufw status verbose y sudo ufw status numbered. Probar los puertos autorizados y no autorizados desde equipos de prueba diferentes. |
| El archivo de configuración de la aplicación puede leerse y modificarse por demasiados usuarios. | Podrían divulgarse credenciales de la base de datos o modificarse la configuración para alterar el comportamiento de ControlNet. | C, I | Aplicar permisos restrictivos y propiedad adecuada; separar la cuenta de ejecución web de las cuentas administrativas y proteger los secretos. | El control de acceso y el mínimo privilegio permiten limitar el acceso a información sensible según las funciones asignadas (Ross & Pillitteri, 2024, control 03.01.05). | Ejecutar stat y namei -l sobre el archivo; probar su lectura y modificación con la cuenta de aplicación y con usuarios sin autorización. Verificar que los servicios sigan funcionando. |
| El volumen secundario se monta automáticamente y no está cifrado. | Si se extrae el disco, otra persona podría leer directamente contratos, documentos y respaldos. | C | Cifrar el volumen con LUKS y controlar las credenciales de desbloqueo. Mantener controles de acceso una vez montado. | LUKS cifra datos a nivel de bloque y protege la información almacenada cuando el dispositivo está apagado o se pierde, siempre que el volumen permanezca bloqueado y las claves estén protegidas (Canonical, s. f.-c). | Verificar con cryptsetup status y lsblk -f que el volumen utilice LUKS. En un entorno de prueba, comprobar que sin desbloquearlo no puedan leerse los datos y que, tras desbloquearlo, los usuarios sigan sujetos a los permisos previstos. |

## 2. Decisiones de priorización

## I. ¿Cuáles son los tres riesgos que atenderia primero?

Recomiendo atender primero las debilidades que combinan privilegios elevados, acceso remoto y exposición de información crítica.

- Privilegios administrativos excesivos y cuentas sin control - Prioridad crítica: La cuenta soporte tiene privilegios superiores a los necesarios y proveedor sigue activa sin vencimiento. Un compromiso de estas cuentas podría afectar el sistema operativo, la información de clientes y la disponibilidad de ControlNet. La primera acción sería reducir privilegios y revocar accesos que ya no sean necesarios.
- Acceso administrativo remoto mediante SSH - Prioridad alta: Las contraseñas compartidas dificultan la atribución de responsabilidades y elevan el riesgo de suplantación. Se debe revisar la autenticación efectiva, individualizar las cuentas, restringir los orígenes de conexión y controlar las llaves. Estos cambios requieren coordinación para no interrumpir la administración.
- Servicios desconocidos y firewall sin política documentada - Prioridad alta: No se conoce con precisión qué servicios aceptan conexiones ni quién necesita utilizarlos. Esto amplía la superficie de ataque. Deben identificarse las dependencias reales de ControlNet y limitarse los accesos de red antes de retirar servicios o bloquear puertos.

La clasificación es preliminar: no se dispone de resultados de explotación, registros de incidentes ni un inventario completo de activos. El volumen sin cifrar y la configuración con secretos accesibles también requieren atención prioritaria, especialmente por la sensibilidad de los documentos de clientes. En la práctica, varias acciones de contención pueden ejecutarse en paralelo.

La justificación se relaciona con el mínimo privilegio y la gestión de cuentas de NIST, así como con las capacidades de control de acceso remoto de OpenSSH y filtrado de tráfico de UFW (Ross & Pillitteri, 2024; Canonical, s. f.-a, s. f.-b).

## II. ¿Qué cuentas necesitan privilegios administrativos?

La asignación debe depender de las tareas y no únicamente del puesto de trabajo.

| Cuenta | Privilegios recomendados | Justificación |
|---|---|---|
| admininfra | Administrativos sobre el sistema operativo, con acceso protegido. | Es responsable de administrar Linux, los servicios del sistema y sus configuraciones. |
| webadmin | Limitados a la aplicación y sus archivos de despliegue. | Mantiene ControlNet, pero no necesita automáticamente privilegios completos sobre el sistema operativo. |
| soporte | Privilegios limitados y específicos. | Debe diagnosticar incidentes, revisar servicios y ejecutar tareas autorizadas, sin disponer de administración irrestricta. |
| provedor | Acceso temporal, limitado al trabajo contratado. | Debe habilitarse solo durante la intervención autorizada y revocarse al terminar. |

La cuenta de la aplicación web, si existe separadamente de webadmin, también debería operar con permisos mínimos y sin privilegios administrativos generales. Para aplicar este diseño, revisaría la pertenencia a grupos privilegiados, las reglas de sudo, los permisos de archivos y los accesos de la aplicación. Después probaría las operaciones que cada rol necesita y comprobaría que las acciones fuera de su responsabilidad sean denegadas. Esta separación disminuye la posibilidad de que un error o compromiso en una cuenta afecte a todo el servidor. Corresponde al mínimo privilegio y a la separación de funciones descritos por NIST (Ross & Pillitteri, 2024, controles 03.01.04 y 03.01.05).

## III. Antes de modificar SSH, ¿qué información revisaría y qué evidencia obtendría?

Primero realizaría una auditoría de solo lectura para conocer la configuración efectiva y las dependencias existentes.

| Información | Evidencia o comando de referencia |
|---|---|
| Configuración principal y archivos complementarios | Copia de respaldo de /etc/ssh/sshd_config y revisión de /etc/ssh/sshd_config.d/. |
| Opciones efectivas de autenticación | sudo sshd -T |
| Cuentas con acceso remoto | Revisión de cuentas locales, grupos autorizados y reglas como AllowUsers o AllowGroups, si existen. |
| Llaves públicas autorizadas | Inventario de authorized_keys, usuarios propietarios y restricciones de cada entrada. |
| Llaves de automatización | Inventario de propietarios, equipos de origen, destinos, usos y permisos de las llaves de respaldo. |
| Conexiones y registros actuales | who, w, last y registros del servicio SSH disponibles en el sistema. |
| Configuración de privilegios | sudo -l -U usuario para cada cuenta relevante, con los permisos adecuados para consultar esa información. |

También verificaría qué usuarios necesitan SSH, si existen procesos automatizados que dependan de él y si hay una consola local o un método alternativo de recuperación.

La documentación de Ubuntu indica que el comportamiento de sshd se configura en el archivo principal y que pueden utilizarse archivos complementarios; además, las llaves permiten autenticación criptográfica sin depender de contraseñas de acceso remoto (Canonical, s. f.-a).

Control propuesto: establecer cuentas individuales, permitir el acceso únicamente a los usuarios autorizados, utilizar llaves públicas controladas y evaluar la desactivación de la autenticación por contraseña una vez comprobado que todos los accesos legítimos pueden funcionar de forma segura.

Comprobación: validar la configuración con sudo sshd -t, revisar sus opciones efectivas con sudo sshd -T y realizar pruebas desde una segunda sesión antes de cerrar la conexión administrativa original.

Riesgo residual: una llave privada comprometida, una cuenta autorizada vulnerable o una mala configuración de privilegios podría permitir todavía un acceso indebido.

## IV. ¿Qué comunicaciones necesita realmente ControlNet?

No debe asumirse que todos los servicios internos tienen que estar disponibles para toda la red. El firewall debe diseñarse con base en los flujos legítimos de comunicación.

| Flujo | Decisión propuesta | Información necesaria |
|---|---|---|
| Trabajadores → ControlNet | Permitir el puerto y protocolo realmente utilizados por la aplicación. | Puerto de escucha, protocolo, usuarios y subredes autorizadas. |
| Equipos administrativos → SSH | Permitir TCP/22 solo desde los equipos o segmentos de administración autorizados, si ese es el puerto configurado. | Orígenes legítimos, puerto efectivo de SSH y mecanismo de acceso remoto. |
| Servidor → base de datos | Permitir únicamente el tráfico requerido si la base de datos es un servicio separado. | Dirección del destino, puerto, protocolo y dependencia de la aplicación. |
| Servidor → servicios de respaldo | Permitir las conexiones necesarias para la automatización de respaldos. | Destinos, horarios, puertos y sentido de las conexiones. |

| | | |
|---|---|---|
| Equipos no autorizados → servicios desconocidos | Bloquear el acceso no necesario y deshabilitar los servicios que no tengan justificación operativa. | Inventario de procesos, puertos, propietarios y dependencias. |

No se puede afirmar que ControlNet necesite HTTP, HTTPS o un puerto de base de datos concreto sin revisar la instalación real. Es necesario comprobarlo antes de establecer las reglas.

Para decidir, recopilaría:

- Puertos y direcciones en escucha mediante sudo ss -lntup.
- Servicios activos mediante systemctl --type=service --state=running.
- Arquitectura y dependencias de ControlNet.
- Subredes, direcciones de origen y destinos legítimos.
- Requisitos de administración, respaldos y monitorización.
- Reglas existentes del firewall y registros de conexiones.

Canonical documenta que UFW permite administrar el firewall del host, abrir o cerrar puertos y restringir el acceso según el origen de la conexión (Canonical, s. f.-b).

- Control propuesto: documentar los flujos permitidos, aplicar una política restrictiva para conexiones entrantes y habilitar únicamente los servicios necesarios.
- Comprobación: verificar las reglas activas y probar desde una estación autorizada y otra no autorizada que los flujos permitidos funcionan y los restantes se rechazan.
- Riesgo residual: las reglas no sustituyen la seguridad de la aplicación, la segmentación de red ni el control de equipos internos comprometidos.

## V. ¿Cuándo son necesarios los permisos, el cifrado o ambos?

Los permisos del sistema de archivos y el cifrado resuelven problemas diferentes. No son controles intercambiables.

- Permisos del sistema operativo: Son necesarios para decidir qué usuarios y procesos pueden leer, modificar o ejecutar un archivo mientras el sistema está funcionando. En DeltaCom deben proteger la configuración de ControlNet y los documentos de clientes, con permisos de lectura y escritura limitados a los roles que realmente los requieren.
- Cifrado: Es necesario cuando se requiere proteger la información almacenada frente a escenarios como la pérdida o extracción física del dispositivo. Para el volumen secundario, LUKS permite cifrar el almacenamiento a nivel de bloque (Canonical, s. f.-c).
- Permisos y cifrado combinados: Conviene utilizar ambos cuando la información es sensible y debe protegerse tanto durante el uso normal del sistema como frente a la pérdida física del disco. En DeltaCom, esta combinación es adecuada para los documentos de clientes, los respaldos y los archivos de configuración que contengan secretos.

En particular, el archivo de configuración que contiene credenciales de la base de datos debe ser legible únicamente por las cuentas que lo necesitan y modificable por un conjunto todavía más reducido de responsables. Si se cifrara el volumen, esas restricciones seguirían siendo necesarias después de desbloquearlo.

- Comprobación: revisar propietarios y permisos con stat y namei -l; probar el acceso con usuarios autorizados y no autorizados; y comprobar por separado el estado de cifrado y el comportamiento del volumen bloqueado.
- Riesgo residual: el cifrado de disco no impide el acceso de un usuario autorizado mientras el volumen está desbloqueado, y los permisos no protegen por sí solos contra la extracción física de un disco sin cifrar.

## VI. ¿Qué ocurriría si alguien copiara una llave privada de respaldo?

Una llave privada permite autenticarse como la identidad a la que corresponde, siempre que el sistema de destino la acepte y no existan otras restricciones que lo impidan. Por ello, copiar una llave de respaldo podría permitir a una persona no autorizada conectarse al destino de los respaldos o ejecutar las operaciones autorizadas para esa llave.

El impacto depende de los permisos y de las restricciones efectivas. Podría incluir la lectura o extracción de información, la modificación de archivos o la eliminación de copias, afectando a la confidencialidad, integridad y disponibilidad.

Propongo los siguientes controles:

1. Inventariar las llaves: registrar propietario, finalidad, equipo de origen, destino y responsable.
2. Proteger los archivos privados: limitar la lectura a la cuenta que ejecuta la tarea de respaldo y evitar que otros usuarios puedan copiarlos.
3. Limitar las capacidades de cada llave: restringir las operaciones y los destinos a los estrictamente necesarios, en vez de conceder acceso administrativo general.
4. Proteger los destinos: utilizar una cuenta de respaldo con permisos limitados y evitar que una llave permita borrar todas las copias históricas.
5. Gestionar el ciclo de vida: revocar o sustituir las llaves comprometidas y retirar las que ya no sean necesarias.
6. Registrar y supervisar el uso: revisar conexiones, fallos de autenticación y actividades inusuales.

Ubuntu documenta el uso de llaves públicas y privadas en OpenSSH y la necesidad de controlar qué cuentas pueden autenticarse mediante ellas (Canonical, s. f.-a).

- Comprobación: en un entorno de pruebas, intentar utilizar una llave para una operación autorizada y otra no autorizada. La primera debe funcionar y la segunda debe ser rechazada. También verificaría que una llave revocada deje de permitir el acceso.
- Riesgo residual: si una llave robada sigue siendo válida y conserva permisos excesivos, el atacante podría aprovecharlos hasta que se retire el acceso o se aplique una restricción efectiva.

## VII. ¿Qué riesgo reduce LUKS y qué no resuelve por sí solo?

LUKS permite cifrar el contenido del volumen a nivel de bloque. En el caso de DeltaCom, esto reduciría el riesgo de que alguien extraiga el segundo disco y lea directamente los respaldos, contratos y documentos históricos desde otro equipo sin disponer del mecanismo de desbloqueo.

La propuesta consiste en migrar el volumen a una configuración cifrada, proteger la frase de paso o el mecanismo de desbloqueo, documentar quién puede autorizarlo y establecer un procedimiento de recuperación seguro.

Antes de realizar la migración, comprobaría la compatibilidad del sistema, la disponibilidad de espacio y respaldos verificados. No debe aplicarse directamente sobre un volumen con información importante sin un procedimiento probado de recuperación.

La documentación de seguridad de Ubuntu explica que LUKS cifra los datos almacenados y requiere desbloquear la clave del volumen para acceder al contenido (Canonical, s. f.-c).

Sin embargo, el cifrado del volumen no resuelve por sí solo:

- El acceso indebido cuando el volumen ya está desbloqueado.
- La eliminación o modificación de archivos por un usuario autorizado.
- El robo de una clave de desbloqueo.
- La exposición de archivos copiados a otros discos sin cifrar.
- La pérdida de disponibilidad por fallos del disco o corrupción de datos.

Comprobación: verificar el tipo de volumen con `lsblk -f`, revisar su estado con `cryptsetup status` cuando esté abierto y probar en un entorno controlado que los datos no sean legibles desde el dispositivo cifrado bloqueado. Una prueba de recuperación debe demostrar también que los responsables autorizados pueden recuperar los datos.

Riesgo residual: si el volumen está desbloqueado o el mecanismo de desbloqueo es comprometido, los datos pueden quedar expuestos. LUKS tampoco sustituye las copias de seguridad, el control de acceso ni la supervisión.

## VIII. Diseñe una prueba positiva y una negativa

Selecciono el control de acceso administrativo por SSH porque el caso describe contraseñas disponibles, credenciales compartidas y llaves sin inventario claro.

- Objetivo de la prueba: demostrar que únicamente las identidades autorizadas pueden acceder al servidor mediante el mecanismo establecido.

**Prueba positiva: acceso autorizado**

- Preparar una cuenta individual aprobada para administrar el servidor.
- Configurar una llave pública válida en la cuenta correspondiente.
- Conectarse desde un equipo de administración autorizado.
- Comprobar que la sesión se establece y que el usuario puede ejecutar únicamente las acciones asignadas a su rol.

Resultado esperado: conexión exitosa, identidad identificable en los registros y privilegios limitados a las tareas autorizadas.

**Prueba negativa: acceso no autorizado**

- Intentar conectarse con una cuenta de prueba que no esté autorizada para SSH.
- Comprobar que la autenticación no sea aceptada.
- Intentar, con una cuenta de soporte de privilegios limitados, ejecutar una operación administrativa que no corresponda a su función.

Resultado esperado: el acceso remoto no autorizado debe rechazarse y la operación administrativa no permitida debe ser denegada.

Evidencias que conservaría: copia de la configuración anterior y posterior, resultado de sshd -t, salida de sshd -T, registros de autenticación y capturas o transcripciones de ambas pruebas, con fecha, cuenta y equipo de origen. Se deben eliminar o redactar contraseñas, llaves privadas y otros secretos de la evidencia.

- Precaución: estas pruebas deben ejecutarse en un entorno autorizado y con una sesión administrativa alternativa disponible. Antes de desactivar la autenticación por contraseña, debe comprobarse que la autenticación por llaves funciona para todos los accesos legítimos necesarios.
- Riesgo residual: una cuenta autorizada podría ser comprometida, una llave privada podría ser robada o una regla de privilegios podría conceder más permisos de los previstos. Por eso, una prueba satisfactoria debe complementarse con revisiones periódicas y seguimiento de registros.

## 3. Síntesis técnica

El análisis de Grupo DeltaCom permite identificar un patrón general de debilidad relacionado con la falta de control sistemático sobre las cuentas, los privilegios, los servicios de red y la protección de la información almacenada. Aunque la empresa dispone de mecanismos como SSH y permisos del sistema de archivos, su existencia no garantiza por sí misma una protección adecuada si no se configuran, documentan y verifican correctamente.

En primer lugar, es necesario aplicar el principio de mínimo privilegio, de manera que cada usuario y proceso disponga únicamente de los permisos requeridos para sus funciones. Ross y Pillitteri (2024) establecen criterios de gestión de cuentas, separación de responsabilidades y revisión de privilegios que permiten fundamentar esta medida. En consecuencia, DeltaCom debe reducir los privilegios de soporte, retirar los accesos externos innecesarios y utilizar identidades individuales para mejorar la trazabilidad.

En segundo lugar, debe establecer una política documentada de acceso remoto y filtrado de tráfico, limitando SSH y los demás servicios a los usuarios, equipos y comunicaciones que realmente los necesiten. La documentación de Canonical (s. f.-a, s. f.-b) proporciona mecanismos para configurar OpenSSH y administrar el firewall del servidor. Finalmente, el cifrado LUKS debe complementar los permisos existentes para proteger los datos ante la pérdida física del almacenamiento.

La estrategia recomendada consiste en identificar los riesgos, aplicar controles proporcionales, comprobar su funcionamiento y conservar evidencias. La seguridad debe tratarse como un proceso continuo de revisión, no como una configuración que se considera segura indefinidamente.

## 4. Referencias bibliográficas en formato APA 7


- Canonical. (s. f.-a). OpenSSH server. Ubuntu Server documentation. https://ubuntu.com/server/docs/how-to/security/openssh-server/
- Canonical. (s. f.-b). Firewall. Ubuntu Server documentation. https://ubuntu.com/server/docs/firewalls/
- Canonical. (s. f.-c). Full disk encryption (FDE). Ubuntu security documentation. https://documentation.ubuntu.com/security/security-features/storage/encryption-full-disk/
- Ross, R., & Pillitteri, V. (2024). Protecting Controlled Unclassified Information in Nonfederal Systems and Organizations (NIST SP 800-171 Rev. 3). National Institute of Standards and Technology. https://doi.org/10.6028/NIST.SP.800-171r3